



1. Visão Geral do Projeto

O **SecCloud** é uma ferramenta educacional que simula ataques cibernéticos reais contra APIs em ambiente controlado. O objetivo é demonstrar, de forma visual e interativa, como diferentes tipos de ataque funcionam e como proteções de segurança mitigam esses riscos.

☐ **Objetivo Educacional**

Demonstrar na prática a diferença entre uma API sem proteções (vulnerável) e uma API com mecanismos de defesa ativos (protegida), executando ataques reais e observando os resultados em tempo real.

1.1 Arquitetura do Ambiente

O projeto é composto por 4 serviços rodando em containers Docker:

Serviço	Porta	Função
Dashboard (SecCloud)	:5050	Interface web — painel de controle dos ataques
API Vulnerável	:8081	API FastAPI sem proteções de segurança ativas
API Protegida	:8082	Mesma API com rate limiting e bloqueio por IP
PostgreSQL	:5432	Banco de dados com 100.000 registros de transações

Fluxo dos dados: `Atacante (Dashboard)` → `API Vulnerável :8081` ou `API Protegida :8082`
→ `PostgreSQL :5432`

1.2 Credenciais do Banco de Dados

O usuário administrador inserido automaticamente pelo seed:

Campo	Valor
Usuário	admin
Senha	senha_secreta
Outros usuários	alice / senha_alice · bob / senha_bob · carlos / senha_carlos

1.3 Como Iniciar o Ambiente

1. **Pré-requisito:** Docker Desktop em execução
2. `bash reiniciar.sh` — faz rebuild completo e inicia todos os containers
3. Aguarde o `:8081` e o `:8082` ficarem verdes no header do dashboard
4. Acesse: `http://localhost:5050`

⚠ Atenção

Após um ataque DoS bem-sucedido, a API Vulnerável pode ficar offline por 30–60 segundos enquanto se recupera. Aguarde o indicador `:8081` voltar ao verde antes de executar novos ataques.

2. Navegação da Interface

A interface é organizada em 5 páginas acessíveis pelo menu superior:

Página	Função Principal
Visão Geral	Status das APIs, métricas gerais e ações rápidas
Ataques	Configurar e executar simulações de Brute Force e DoS
Logs	Visualizar logs em tempo real das APIs e do gateway
Relatórios	Histórico de todos os ataques executados
Teste Manual	Enviar requisições individuais para explorar as APIs

No canto superior direito há dois indicadores de status: :8081 (API Vulnerável) e :8082 (API Protegida). Verde = online, Vermelho = offline. Clique em **↻ Atualizar** para forçar verificação imediata.

3. Página: Visão Geral

É a página inicial do dashboard. Exibe o estado completo do ambiente em tempo real.

3.1 Cards de Status das APIs

Dois cards lado a lado mostram o estado atual de cada API:

Campo	API Vulnerável	API Protegida
Modo	VULNERÁVEL	PROTEGIDA
Rate Limit	☐ Desativado	☐ 2 req/s por IP
Bloqueio por IP	☐ Não	☐ 3 falhas → bloqueio de 60s
Badge de status	Online / Offline	Online / Offline

3.2 Métricas Rápidas

Quatro contadores abaixo dos cards de API:

- **Senhas na Wordlist:** total de senhas disponíveis para Brute Force (447 senhas)
- **Ataques BF Salvos:** quantidade de relatórios de Brute Force gerados na sessão
- **Ataques DoS Salvos:** quantidade de relatórios de DoS gerados
- **APIs Online:** ex: "2/2" significa ambas funcionando; "1/2" indica problema

3.3 Diagrama de Arquitetura

Representação visual do fluxo do ambiente: [Atacante](#) → [Dashboard](#) → [API Vulnerável](#) → [PostgreSQL](#) e [API Protegida](#). Cada nó exibe um indicador verde (online) ou vermelho (offline) em tempo real.

3.4 Ações Rápidas

Botões de atalho para iniciar ataques diretamente sem navegar até a página de Ataques:

- [BF — Vulnerável](#): inicia Brute Force na API sem proteção
- [BF — Protegida](#): inicia Brute Force na API com bloqueio por IP
- [DoS — Vulnerável](#): inicia ataque de negação de serviço na API sem rate limit
- [DoS — Protegida](#): inicia DoS na API com rate limiting ativo
- [Logs](#) e [Relatórios](#): atalhos de navegação

4. Página: Simulação de Ataques

É a página principal do simulador. Contém dois painéis independentes: Brute Force e DoS.

4.1 Ataque de Força Bruta (Brute Force)

❑ O que é Brute Force?

Um ataque de força bruta testa sistematicamente uma lista de senhas contra um endpoint de login até encontrar a correta. Demonstra a necessidade de mecanismos de bloqueio por IP após múltiplas tentativas falhas.

Endpoint atacado

POST /login com corpo: {"username": "admin", "password": "<senha_da_wordlist>"}

Parâmetros configuráveis

Campo	Valores	Descrição
Alvo	API Vulnerável / API Protegida	Qual API receberá o ataque
Max. Tentativas	1 a 447	Quantas senhas da wordlist testar (padrão: 20)

O que acontece durante o ataque

5. **Vulnerável:** cada senha é testada individualmente. A API responde 401 para todas as senhas erradas, sem nunca bloquear o IP. O ataque continua até esgotar a wordlist ou encontrar a senha.
6. **Protegida:** após 3 tentativas falhas consecutivas, a API retorna 429 (Too Many Requests) e bloqueia o IP por 60 segundos. O ataque é interrompido automaticamente.

Console de Execução

O console exibe em tempo real cada tentativa com código de cor:

- **Verde (SUCESSO):** 200 — senha encontrada
- **Laranja (BLOQUEADO):** 429 — IP bloqueado pelo rate limiting
- **Vermelho (FAIL):** 401 — senha incorreta, tentativa continua

Exemplo de saída no console:

```
[00:50:15]  FAIL  [1/20] "123456" → 401 (0.76s)
[00:50:16]  FAIL  [2/20] "password" → 401 (0.72s)
[00:50:16]  FAIL  [3/20] "master" → 401 (0.76s)
... (continua até encontrar ou esgotar a lista)
```

```
[00:50:21] SUCCESS ☐ Concluído — ataque_bruteforce_vuln_20260322.json
```

Resultado exibido após o ataque

Situação	Mensagem	O que significa
Senha encontrada	☐ Senha encontrada: "senha_secreta"	API vulnerável comprometida
IP bloqueado	☐ IP bloqueado após N tentativas	Proteção funcionou corretamente
Não encontrada	☐ Senha não encontrada em N tentativas	Senha não estava na wordlist

Métricas exibidas

- **Tentativas:** quantas senhas foram testadas
- **Tempo total:** duração do ataque em segundos
- **Gráfico de barras:** distribuição dos códigos HTTP (401, 429, 200)

☐ Dica para demonstração completa

Para ver o Brute Force encontrar a senha, a wordlist padrão (senhas comuns em inglês) não contém "senha_secreta". Adicione essa linha ao arquivo atacante/wordlist.txt antes de rodar o ataque na API Vulnerável.

4.2 Ataque de Negação de Serviço (DoS)

☐ O que é DoS?

Um ataque DoS envia múltiplas requisições simultâneas para sobrecarregar o servidor. O endpoint `/relatorio` executa uma query pesada que busca 100.000 registros do banco sem paginação — alvo ideal para esgotamento de recursos.

Endpoint atacado

`GET /relatorio` — retorna todos os 100.000 registros de transações sem paginação

Parâmetros configuráveis

Campo	Valores	Descrição
Alvo	API Vulnerável / API Protegida	Qual API receberá o ataque
Workers	1 a 100	Threads paralelas enviando requisições (padrão: 20)

Duração	5 a 60 segundos	Por quanto tempo o ataque continuará (padrão: 15s)
---------	-----------------	--

O que acontece durante o ataque

7. **Vulnerável:** todos os workers enviam requisições simultaneamente sem restrição. A API aceita tudo, esgota o pool de conexões do banco e começa a retornar timeouts. A API pode cair completamente e levar 30–60s para se recuperar.
8. **Protegida:** o rate limiting bloqueia com 429 as requisições que excedem 2 por segundo por IP. A maioria das requisições é rejeitada rapidamente, preservando os recursos do servidor.

Acompanhamento em tempo real no console

```
[01:26:08]  DOS  [2s/15s] 50 reqs — codes: {"429":50}
[01:26:10]  DOS  [4s/15s] 50 reqs — codes: {"429":50}
[01:26:12]  DOS  [6s/15s] 53 reqs — codes: {"0":2,"429":51}
...
[01:26:23]  SUCCESS  ☐ Concluído — ataque_dos_secure_20260322.json
```

Interpretando os resultados

Código HTTP	Significado	Onde aparece
200	Requisição processada com sucesso	API saudável, baixa carga
429	Bloqueada por rate limiting	API Protegida — sinal positivo de defesa
0 (Timeout)	API não respondeu em 8s	API Vulnerável sobrecarregada
0 (Refused)	Conexão recusada — API caiu	API Vulnerável derrubada pelo DoS

Métricas do resultado final

- **Requisições:** total enviado durante o ataque
- **Tempo médio:** tempo médio de resposta por requisição
- **Recusadas:** conexões recusadas — indica que a API foi derrubada
- **Timeouts:** requisições que não receberam resposta em 8 segundos
- **Gráfico de barras:** proporção visual de cada código HTTP

Resultado esperado por cenário

Cenário	Resultado	Interpretação
DoS → API Vulnerável	☐ API sobrecarregada (60+ timeouts)	Sem proteção: servidor esgota recursos e trava
DoS → API Protegida	☐ Rate limiting bloqueou X de Y requisições	Com proteção: bloqueio rápido, servidor estável

5. Página: Logs do Sistema

Permite visualizar os arquivos de log gerados automaticamente pelas APIs e pelo gateway durante a execução dos ataques.

5.1 Arquivos Disponíveis

Arquivo	Conteúdo	Quando usar
gateway.log	Todas as requisições que passaram pelo proxy reverso	Visão geral do tráfego
api_vulneravel.log	Logs internos da API sem proteção (logins, relatórios)	Ver impacto do ataque na API
api_protegida.log	Logs da API protegida com indicação de bloqueios	Ver rate limiting em ação

5.2 Recursos da Visualização

- **Filtro:** campo de texto para filtrar linhas por palavra-chave (ex: "401", "LOGIN", "RELATORIO")
- ↺ **Atualizar:** recarrega o arquivo de log do servidor (até 300 últimas linhas)
- ↓ **Final:** rola o viewer até a linha mais recente
- **Destaque por cor:** cada código HTTP tem uma cor diferente para facilitar a leitura

5.3 Legenda de Cores

Cor	Código HTTP	Significado
☐ Verde	200 OK	Requisição bem-sucedida
☐ Amarelo	401 Unauthorized	Credenciais inválidas
☐ Vermelho	403 Forbidden	Acesso proibido
☐ Roxo	429 Too Many Requests	Rate limiting ativo
☐ Vermelho	500 Internal Error	Erro interno do servidor

5.4 O que Observar nos Logs

Durante e após cada ataque, os logs mostram padrões distintos:

- **Brute Force na Vulnerável:** sequência longa de entradas com "401" e o mesmo IP
- **Brute Force na Protegida:** poucas linhas "401" seguidas de "429" e mensagem de bloqueio
- **DoS na Vulnerável:** rajada de requisições para /relatorio, depois erros 500 ou ausência de respostas

- **DoS na Protegida:** maioria das linhas com "429" — rate limiting bloqueando o tráfego excessivo

6. Página: Relatórios de Ataques

Lista todos os ataques já executados na sessão, com dados detalhados armazenados em arquivos JSON.

6.1 Lista de Relatórios

Cada linha exibe:

- **Ícone:**  para Brute Force,  para DoS
- **Nome:** "Brute Force — API Vulnerável" ou "DoS — API Protegida"
- **Data e hora:** extraída do nome do arquivo (ex: 22/03/2026 03:50)
- **Métricas resumidas:** tentativas e status para BF; requisições e tempo médio para DoS
- **Seta:** clique no item para expandir os detalhes completos

6.2 Detalhes Expandidos — Brute Force

Campo	Descrição
Tentativas	Quantas senhas foram testadas
Senha	Valor encontrado ou "Não achada"
Tempo Total	Duração completa do ataque
Gráfico de códigos	Proporção de 401 / 429 / 200 com barras coloridas

6.3 Detalhes Expandidos — DoS

Campo	Descrição
Requisições	Total enviado durante o ataque
Tempo Médio	Média de tempo de resposta por requisição
P95	Percentil 95 — 95% das respostas foram mais rápidas que esse valor
Recusadas	Conexões recusadas (API sem recursos para aceitar)
Timeouts	Requisições sem resposta em 8 segundos
Gráfico de códigos	Distribuição de 200 / 429 / 0 com barras coloridas

6.4 Onde os Relatórios são Salvos

Cada ataque gera automaticamente um arquivo JSON na pasta `logs/` do projeto. Exemplo de nome: `ataque_bruteforce_vuln_20260322_035019.json`. O módulo `monitoramento/metricas.py` pode ser usado para comparar relatórios e gerar CSVs comparativos.

7. Página: Teste Manual de Endpoints

Permite enviar requisições individuais para qualquer endpoint das APIs, com feedback imediato do código HTTP e do corpo da resposta.

7.1 Endpoints Disponíveis

Endpoint	Método	Parâmetros	O que testa
GET /health	GET	Apenas: alvo (vuln/secure)	Se a API está online e qual modo está ativo
POST /login	POST	Alvo, usuário, senha	Autenticação com credenciais específicas
GET /relatorio	GET	Apenas: alvo (vuln/secure)	Query pesada — busca 100k registros
POST /login (bloqueio)	POST	Alvo, senha aleatória	Acumular falhas para testar logout por IP

7.2 Resultados Esperados por Teste

GET /health

- **Esperado (ambas as APIs):** HTTP 200 com {"status": "ok", "modo": "VULNERÁVEL"} ou "PROTEGIDA"

POST /login com credenciais corretas

- **Admin correto:** HTTP 200 com {"mensagem": "Login bem-sucedido", "usuario": "admin"}
- **Credenciais:** admin / senha_secreta

POST /login com senha errada

- **Ambas as APIs:** HTTP 401 com {"erro": "Credenciais inválidas"}
- **API Protegida após 3 falhas:** HTTP 429 — IP bloqueado por 60 segundos

GET /relatorio

- **Vulnerável:** HTTP 200 com JSON de 100.000 registros (pode demorar vários segundos)
- **Protegida (>2 req/s):** HTTP 429 — rate limiting ativo

POST /login — Teste de Bloqueio (botão especial)

O 4º card envia repetidamente senhas aleatórias para demonstrar o logout:

- **API Protegida:** clique 3 vezes → na 4ª o IP é bloqueado com [HTTP 429](#)
- **API Vulnerável:** pode clicar indefinidamente → sempre retorna [HTTP 401](#) sem bloquear

7.3 Interpretando o Código de Resposta

Código	Cor	Significado no contexto
200	☐ Verde	Operação bem-sucedida
401	☐ Vermelho	Credenciais inválidas — tentativa de login falhou
429	☐ Vermelho	Rate limiting ou bloqueio por IP ativo
404	☐ Vermelho	Endpoint não existe nessa API
500	☐ Vermelho	Erro interno — API possivelmente sobrecarregada

8. Roteiros de Demonstração Sugeridos

8.1 Demonstração Rápida (10 minutos)

Para apresentar o projeto de forma objetiva:

9. **Visão Geral:** mostre o diagrama de arquitetura e explique os dois modos de API
10. **Brute Force na Protegida:** configure 5 tentativas, execute — demonstre o bloqueio por IP (429)
11. **Brute Force na Vulnerável:** execute com as mesmas configurações — mostre que nunca bloqueia (401 repetidos)
12. **Teste Manual:** use o botão de bloqueio na API Protegida para mostrar o 429 interativamente
13. **Logs:** mostre a diferença visual entre os logs das duas APIs

8.2 Demonstração Completa (20 minutos)

14. **Visão Geral:** explique toda a arquitetura e as proteções implementadas
15. **Brute Force comparativo:** execute na Vulnerável (encontra senha com wordlist editada) e na Protegida (bloqueia)
16. **DoS na Protegida:** execute com 20 workers, 15s — mostre rate limiting bloqueando 429
17. **DoS na Vulnerável:** execute — mostre timeouts e API possivelmente caindo
18. **Comparação de Logs:** abra gateway.log e filtre por "429" para mostrar o volume bloqueado
19. **Relatórios:** mostre o histórico comparativo, explique as métricas P95 e tempo médio
20. **Teste Manual:** execute /relatorio em ambas as APIs para sentir a diferença de resposta

8.3 Perguntas Frequentes para Discussão

□ Tópicos para debate com a equipe

21. Por que a API vulnerável demora tanto para responder? (query sem paginação em 100k registros)
22. O rate limiting de 2 req/s é suficiente? Quais outros mecanismos poderiam complementar?
23. Um atacante real esperaria os 60s de bloqueio e tentaria de novo. Como isso seria mitigado?
24. O DoS conseguiu derrubar a API com apenas 20 workers. Em produção, quantos atacantes simultâneos seriam necessários?

9. Referência Rápida

9.1 Comandos Essenciais

Ação	Comando
Iniciar ambiente completo (rebuild)	bash reiniciar.sh
Diagnosticar problemas	bash diagnostico.sh
Reiniciar só o dashboard	docker compose restart dashboard
Reiniciar API Vulnerável	docker compose restart api-vulneravel
Ver logs em tempo real	docker compose logs -f api-vulneravel
Verificar status dos containers	docker compose ps
Parar tudo	docker compose down

9.2 Credenciais e URLs

Serviço	URL / Credencial
Dashboard	http://localhost:5050
API Vulnerável	http://localhost:8081
API Protegida	http://localhost:8082
Debug de URLs	http://localhost:5050/api/debug
Login admin	admin / senha_secreta
Outros usuários	alice/senha_alice · bob/senha_bob · carlos/senha_carlos

9.3 Cheat Sheet — Resultados Esperados

Ataque	Alvo	Resultado esperado	Código HTTP
Brute Force	Vulnerável	Testa todas as senhas — nunca bloqueia	401 repetidos
Brute Force	Protegida	Bloqueia após 3 falhas	401 × 3 → 429
DoS (20w, 15s)	Vulnerável	API sobrecarregada — timeouts ou queda	0 (timeout/refused)
DoS (20w, 15s)	Protegida	Rate limiting bloqueia a maioria	429 (maioria)
GET /health	Ambas	Status online e modo ativo	200
POST /login (correto)	Ambas	Login bem-sucedido	200
POST /login (errado)	Ambas	Credenciais inválidas	401

GET /relatorio	Vulnerável	Retorna 100k registros (lento)	200
GET /relatorio	Protegida (>2/s)	Bloqueado por rate limit	429

□ Resumo das Proteções Implementadas na API Protegida

- **Bloqueio por IP no login:** após 3 tentativas falhas, o IP é bloqueado por 60 segundos
- **Rate limiting no /relatorio:** máximo de 2 requisições por segundo por IP
- **Limite de CPU:** container da API Protegida limitado a 0.5 CPU via Docker
- **Hash seguro de senha:** bcrypt com salt aleatório para armazenamento das senhas no banco